

# Phishing & Email Security

Comprehensive Study & Interview Notes

## Phishing Definition

Phishing is a social engineering attack where attackers trick users into:

- Clicking malicious links
- Opening infected attachments
- Sharing credentials or sensitive data

## Main Goals of Phishing

- Credential theft
- Malware delivery
- Financial fraud
- Unauthorized access

## Types of Phishing

| Type           | Description                                     |
|----------------|-------------------------------------------------|
| Email Phishing | Fake emails sent to many users                  |
| Spear Phishing | Targeted phishing attack                        |
| Whaling        | Targets executives                              |
| Smishing       | SMS phishing                                    |
| Vishing        | Voice-call phishing                             |
| Clone Phishing | Copy of legitimate email with malicious changes |

## Common Indicators

- Suspicious sender email
- Urgent language
- Fake login pages
- Misspelled domains
- Unexpected attachments
- Grammar mistakes
- Requests for passwords or OTPs

## Dangerous File Types

| File Type | Risk              |
|-----------|-------------------|
| .docm     | Macro malware     |
| .xlsm     | Malicious scripts |
| .zip      | Hidden malware    |

| File Type | Risk               |
|-----------|--------------------|
| .exe      | Executable malware |
| .html     | Fake login page    |

## Important Email Security Protocols

**SPF:** Verifies authorized mail server.

**DKIM:** Checks email integrity using digital signatures.

**DMARC:** Defines action for failed authentication emails.

## SOC Analyst L1 Responsibilities

- Analyze suspicious emails
- Check headers and URLs
- Identify IOCs
- Investigate attachments
- Escalate confirmed incidents

## Common IOCs in Phishing

- Malicious URLs
- Suspicious IPs
- File hashes
- Fake domains
- Malicious attachments

## Phishing Prevention

- User awareness training
- MFA enabled
- Email filtering
- Endpoint protection
- Regular patching

## Quick Flow of Phishing Attack

1. Fake email sent
2. User clicks link
3. Credentials stolen or malware executed
4. Attacker gains access

## Important Terms

| Term          | Meaning                 |
|---------------|-------------------------|
| IOC           | Indicator of Compromise |
| Spoofing      | Fake identity           |
| Payload       | Malicious code          |
| Typosquatting | Similar fake domain     |

| Term                  | Meaning                |
|-----------------------|------------------------|
| Credential Harvesting | Stealing login details |

## Interview Questions & Answers

### 1. What is phishing?

Phishing is a social engineering attack used to steal sensitive information or deliver malware through fake emails, messages, or websites.

### 2. What are common signs of phishing?

Suspicious sender, Urgent language, Fake URLs, Unexpected attachments, Grammar mistakes.

### 3. Difference between phishing and spear phishing?

Phishing targets many users. Spear phishing targets a specific individual or organization.

### 4. What should a SOC Analyst check in a phishing email?

Sender address, Email headers, URLs, Attachments, SPF/DKIM/DMARC status.

### 5. What is email spoofing?

Email spoofing is forging the sender's identity to make an email appear legitimate.

### 6. What are SPF, DKIM, and DMARC?

**SPF:** Verifies sending server

**DKIM:** Validates email integrity

**DMARC:** Defines handling policy

### 7. What is an IOC in phishing?

Indicators of Compromise such as malicious domains, IP addresses, hashes, or URLs that indicate suspicious activity.

### 8. Why are macro-enabled files dangerous?

They can execute malicious scripts and download malware.

### 9. What is credential harvesting?

Stealing usernames and passwords using fake login pages.

### 10. How can phishing attacks be prevented?

User awareness, MFA, Email filtering, Endpoint security, Regular updates.

**One-Line Revision:** Phishing is a social engineering attack used to steal credentials or deliver malware using fake emails, links, or attachments.